

CyberOps Mock Test — Questions

57 questions covering Phases 01-07, applied scenarios, and adjacent topics

Duration: 90 minutes | Open Book | Write your answers on a separate sheet

SECTION A — CORE CONTENT

Question 1

[Process Cycle Overview]

Which phase of the Cyber Security Operations Process Cycle feeds back into Phase 01 to create a continuous improvement loop?

- A. Phase 03 — SOC & SIEM
- B. Phase 05 — Workflow Automation
- C. Phase 07 — Remediation, Recovery, Resilience
- D. Phase 04 — Service Management

Question 2

[Phase 02 — Normalisation]

A VPN log uses pipe-delimited format with the timestamp '2024-02-02 10:15:23'. What is the correct normalised timestamp?

- A. 02/02/2024 10:15:23
- B. 2024-02-02T10:15:23Z
- C. 1706866523
- D. Feb 2, 2024 10:15 AM

Question 3

[Phase 02 — Normalisation]

Which of the following are REQUIRED fields in every normalised security event?

- A. normalised_timestamp, event_type, username, severity
- B. normalised_timestamp, event_type, source_type, severity
- C. normalised_timestamp, source_ip, destination_ip, protocol
- D. event_type, source_type, raw_message, additional_details

Question 4

[Phase 02 — Aggregation]

What critical information does simple aggregation (counting) fail to capture?

- A. The type of events occurring in the system
- B. The source IP addresses generating events
- C. The total number of events in the log file
- D. The temporal relationship between events (timing patterns and clustering)

Question 5

[Phase 03 — SIEM]

A SIEM combines two core functionalities. Which component handles real-time monitoring and alerting?

- A. SIM (Security Information Management)
- B. SEM (Security Event Management)
- C. SOC (Security Operations Centre)
- D. SOAR (Security Orchestration, Automation and Response)

Question 6

[Phase 03 — Correlation Rules]

Your brute force correlation rule triggers on 5+ failed SSH logins from the same IP within 120 seconds. It alerts on both 192.168.1.100 (attacker) and 10.0.0.5 (monitoring server). What is the alert fidelity?

- A. 100%
- B. 75%
- C. 50%
- D. 25%

Question 7

[Phase 03 — False Positives]

How does adding a whitelist improve your correlation rule's effectiveness?

- A. It speeds up processing by checking fewer events
- B. It deletes monitoring server logs from the dataset
- C. It excludes known-legitimate sources from alerting, reducing false positives
- D. It blocks whitelisted IPs from accessing the network

Question 8

[Phase 04 — Severity Algorithm]

An alert shows 8 failed login attempts from an unknown IP at 10:30 PM. Using the severity calculation algorithm, what is the final severity?

- A. HIGH — 5-9 events, no time adjustment needed
- B. CRITICAL — 5-9 events becomes HIGH, then off-hours escalates to CRITICAL
- C. MEDIUM — off-hours adjustments only apply to CRITICAL
- D. LOW — the IP might be legitimate

Question 9

[Phase 04 — Severity Algorithm]

A known backup server (whitelisted) generates 15 failed login events at 2:00 AM. What is the final severity?

- A. CRITICAL — 15 events and off-hours
- B. HIGH — whitelisting reduces by one level
- C. MEDIUM — whitelisting reduces by two levels
- D. LOW — whitelisted IPs are always downgraded to LOW regardless of event count

Question 10

[Phase 04 — SLAs]

A CRITICAL severity incident is detected. Which team handles it and what is the response time commitment?

- A. SOC team, 1 hour
- B. Incident Response team, 15 minutes
- C. Network Security, 4 hours
- D. IT Support, 8 hours

Question 11

[Phase 04 — KPIs]

Your organisation's escalation rate increases from 10% to 40% over one month. What does this most likely indicate?

- A. The automation system is working more efficiently
- B. More CRITICAL incidents are occurring, indicating increased threat activity
- C. Teams are responding faster to incidents
- D. SLA response times should be increased

Question 12

[Phase 05 — Workflow Automation]

The alert-to-ticket workflow follows: Alert → Calculate → SLA → Ticket → Route. What pattern does this implement?

- A. Manual processing: analyst review at each step
- B. Aggregation: combining multiple alerts into single tickets
- C. Encryption: securing ticket data during transmission
- D. Orchestration: coordinating multiple automated steps in sequence

Question 13

[Phase 06 — Alert Lifecycle]

During which phase of the alert lifecycle do analysts determine whether an alert is a true positive or false positive?

- A. Detection — where the correlation rule first triggers
- B. Triage — where analysts check whitelists and known patterns
- C. Response — where actions are taken to stop the threat
- D. Documentation — where findings are recorded

Question 14

[Phase 07 — Remediation]

In the remediation planning structure, what is the correct priority sequence?

- A. Eradication → Containment → Recovery → Resilience
- B. Recovery → Containment → Eradication → Resilience
- C. Containment → Eradication → Recovery → Resilience
- D. Resilience → Recovery → Eradication → Containment

Question 15

[Phase 07 — Case Study]

In the GameForge Studios case study, the breach was detected when:

- A. Players reported account issues
- B. A third-party vendor notified them
- C. Unusual database queries were flagged by monitoring
- D. An employee noticed unreleased code online

Question 16

[Lab Skills]

Why is Docker used in the lab environment instead of running scripts directly?

- A. Docker makes Python run faster
- B. Docker is required for all SIEM platforms
- C. Docker provides an isolated, consistent environment with identical data and dependencies
- D. Docker automatically detects security threats

Question 17

[Lab Skills]

The lab pipeline mirrors enterprise SIEM operations. What is the correct sequence?

- A. Visualisation → Analysis → Collection → Parsing → Normalisation
- B. Collection → Parsing → Normalisation → Visualisation → Analysis
- C. Normalisation → Collection → Analysis → Parsing → Visualisation
- D. Parsing → Collection → Normalisation → Analysis → Visualisation

SECTION B — APPLIED SCENARIOS

Question 18

[Log Analysis]

You receive normalised events within 30 seconds from IP 10.20.30.40: vpn_failure, authentication_failure, authentication_success, network_traffic (to a database server). Most likely interpretation?

- A. Normal user activity — mistyped password
- B. Potential breach — failed VPN, successful local auth, suspicious DB access
- C. False positive — unrelated coincidences
- D. System error — logs are out of sync

Question 19

[Operational Analysis]

MTTD improved from 4 hours to 45 minutes, but MTTR worsened from 2 hours to 6 hours. What does this suggest?

- A. SOC is performing poorly across the board
- B. Detection improved (better SIEM rules), but response processes need attention
- C. SIEM is generating too many false positives
- D. The metrics are contradictory and contain errors

Question 20

[Severity Calculation]

At 6:30 AM: 4 failed logins from 172.16.0.50 (not whitelisted) and 11 failed logins from 10.0.0.10 (whitelisted backup server). Final severities?

- A. 172.16.0.50 = HIGH, 10.0.0.10 = CRITICAL
- B. 172.16.0.50 = HIGH (off-hours escalation from MEDIUM), 10.0.0.10 = LOW (whitelist)
- C. 172.16.0.50 = MEDIUM, 10.0.0.10 = LOW
- D. Both = LOW (early morning, likely automated)

SECTION C — ADJACENT TOPICS

Question 21

[Threat Intelligence]

Your SIEM receives a threat intel feed with IP addresses, file hashes, and domain names linked to malware. What are these collectively called?

- A. Correlation rules
- B. Indicators of Compromise (IOCs)
- C. Service Level Indicators (SLIs)
- D. Baseline configurations

Question 22

[Threat Intelligence]

What is the difference between strategic and tactical threat intelligence?

- A. Strategic is automated, tactical is manual
- B. Strategic is high-level trends for executives; tactical is technical detail for analysts (IOCs, TTPs)
- C. Strategic is internal, tactical is external
- D. Strategic is real-time, tactical is historical

Question 23

[MITRE ATT&CK;]

An attacker sends phishing (Initial Access), installs keylogger (Execution), moves to domain controller (Lateral Movement), exfiltrates data. Which framework maps these?

- A. NIST CSF 2.0
- B. MITRE ATT&CK;
- C. ISO 27001
- D. ITIL v4

Question 24

[SOC Tiers]

A junior SOC analyst reviews alerts, checks whitelists, and escalates suspicious ones. Which SOC tier?

- A. Tier 1 — Alert Monitoring and Triage
- B. Tier 2 — Deep Investigation
- C. Tier 3 — Threat Hunting
- D. Tier 4 — SOC Management

Question 25

[Digital Forensics]

During Phase 07 remediation, you preserve evidence from a compromised server. Why create a cryptographic hash of the disk image?

- A. To encrypt evidence from attackers
- B. To compress the image for storage
- C. To prove evidence hasn't been tampered with (chain of custody)
- D. To speed up forensic analysis

Question 26

[GDPR & Compliance]

A data breach affects EU customer personal data. Under GDPR Article 33, within what timeframe must you notify the supervisory authority?

- A. 24 hours
- B. 48 hours
- C. 72 hours
- D. 7 days

Question 27

[BC/DR]

What is the difference between RTO and RPO in disaster recovery?

- A. RTO is for networks, RPO for databases
- B. RTO = how quickly restore service; RPO = how much data loss is acceptable
- C. RTO is set by management, RPO by IT
- D. RTO measures detection, RPO measures response

Question 28

[Vulnerability Management]

GameForge's breach exploited a third-party auth library. Which process should have found this BEFORE exploitation?

- A. Incident response
- B. Vulnerability management (regular scanning and patching including third-party)
- C. Log aggregation
- D. SLA management

Question 29

[NIST CSF 2.0 — GOVERN]

NIST CSF 2.0 introduced a new sixth function. Which was added?

- A. DETECT
- B. GOVERN — aligning cybersecurity strategy with organisational objectives
- C. RESPOND
- D. PROTECT

SECTION B — APPLIED SCENARIOS

Question 30

[Document Analysis]

SOC detected anomalous traffic at 14:32. Attack actually began at 13:00. Calculate MTTD.

- A. 13 minutes (14:32 to 14:45)
- B. 1 hour 32 minutes (13:00 to 14:32)
- C. 3 hours 10 minutes (13:00 to 16:10)
- D. 20 hours (13:00 to 09:00 next day)

Question 31

[Process Cycle Mapping]

A new employee connects a personal laptop with outdated AV and unpatched OS. Which phase should have prevented this?

- A. Phase 02 — logs should flag new devices
- B. Phase 01 — IT Systems Landscape should include asset management and access policies
- C. Phase 05 — automation should block unknown devices
- D. Phase 07 — resilience should account for rogue devices

SECTION C — ADJACENT TOPICS

Question 32

[Log Sources]

A workstation makes hundreds of DNS requests to random subdomains of one domain (a8xk2.evil.com, b9yz1.evil.com). Most likely cause?

- A. Normal web browsing
- B. DNS tunnelling or C2 communication from malware
- C. Misconfigured DNS server
- D. DNS stress test

SECTION B — APPLIED SCENARIOS

Question 33

[Critical Thinking]

An org has a SIEM but no IR playbooks. Ransomware alert fires. Three analysts each do different things. Which phases failed?

- A. Only Phase 06
- B. Phase 04 (no standardised procedures) and Phase 05 (no automated workflows for consistency)
- C. Only Phase 03 — SIEM should have prevented it
- D. Phase 07 — resilience was inadequate

SECTION C — ADJACENT TOPICS

Question 34

[Change Management]

A developer pushes a firewall rule directly to production without approval, opening RDP to the internet. Which concept was violated?

- A. SLA management
- B. Change management — changes must be assessed for security impact before implementation
- C. Capacity management
- D. Knowledge base management

SECTION B — APPLIED SCENARIOS

Question 35

[Full Cycle Walkthrough]

After a phishing attack, the security team writes five new SIEM correlation rules. Which phase is this?

- A. Phase 03 — SOC & SIEM Functions
- B. Phase 05 — Workflow Automation
- C. Phase 06 — Incident Response
- D. Phase 07 — feeding back improvements into Phase 03

SECTION A — CORE CONTENT

Question 36

[Phase 02 — Normalisation]

Windows Event ID 4625 maps to which normalised event type?

- A. authentication_success
- B. authentication_failure
- C. process_execution
- D. network_access

SECTION C — ADJACENT TOPICS

Question 37

[STIX/TAXII]

Your SOC wants to automatically share threat intel with partners. Which standards enable this?

- A. JSON and CSV
- B. STIX (format) and TAXII (transport)
- C. ISO 27001 and ISO 27002
- D. SNMP and Syslog

SECTION B — APPLIED SCENARIOS

Question 38

[Service Management]

An organisation without a SOC detects a breach via their IT service desk. Biggest challenge vs an org with a SOC?

- A. Cannot use a SIEM
- B. Limited specialised security expertise and slower response to complex threats
- C. No way to create incident tickets
- D. Logs cannot be normalised

SECTION A — CORE CONTENT

Question 39

[Phase 05 — Terminology]

What is the difference between a playbook and a runbook?

- A. Playbooks for SOAR; runbooks for SIEM
- B. Playbooks are predefined automated sequences; runbooks are detailed procedures that may include manual steps
- C. Playbooks by management; runbooks by analysts
- D. No difference — synonymous

SECTION C — ADJACENT TOPICS

Question 40

[CVSS]

A vulnerability scanner finds a flaw with CVSS score 9.8. What does this mean?

- A. Low-risk, patch next maintenance window
- B. Critical vulnerability requiring immediate patching — CVSS rates 0 to 10
- C. Number of affected systems
- D. Estimated exploitation cost in thousands

SECTION A — CORE CONTENT

Question 41

[Phase 01 — IT Systems Landscape]

What is the primary purpose of Phase 01 in the Process Cycle?

- A. Install security monitoring tools
- B. Identify and document the entire IT environment — systems, tools, processes, infrastructure
- C. Normalise log data from all sources
- D. Create automated playbooks

Question 42

[Phase 01 — IT Systems Landscape]

Why is Phase 01 considered the foundation of the entire Process Cycle?

- A. It generates the most security alerts
- B. Every other phase depends on knowing what assets and systems exist
- C. It's the only phase using the NIST framework
- D. It automates device detection

Question 43

[Phase 01 — IT Systems Landscape]

An organisation migrated services to the cloud but didn't update Phase 01 documentation. What risk is created?

- A. No risk — cloud is inherently more secure
- B. The SIEM will auto-discover cloud services
- C. Unmonitored cloud assets become blind spots — SOC can't detect threats against unknown systems
- D. SLA response times auto-adjust

SECTION B — APPLIED SCENARIOS

Question 44

[Phase 01 — Asset Management]

An audit finds 15 undocumented servers running production workloads. Which phases are impacted?

- A. Only Phase 01 — just a documentation issue
- B. Phase 01 (undocumented), 02 (no logs), 03 (no monitoring), and all downstream phases
- C. Only Phase 03 — SIEM needs reconfiguring
- D. Only Phase 04 — service catalogue update

SECTION A — CORE CONTENT

Question 45

[Phase 06 — Incident Response]

Phase 06 maps to which NIST CSF 2.0 function?

- A. IDENTIFY
- B. PROTECT
- C. DETECT
- D. RESPOND

Question 46

[Phase 06 — Incident Response]

During active ransomware, what should be the FIRST response action?

- A. Begin restoring from backups
- B. Contain by isolating affected systems to prevent spread
- C. Conduct full forensic analysis
- D. Notify all customers

Question 47

[Phase 06 — Incident Response]

Which BEST describes Phase 05's relationship to Phase 06?

- A. Phase 05 replaces Phase 06 entirely
- B. Phase 05 automates initial response, coordinates teams, and tracks progress, supporting Phase 06
- C. Phase 06 must complete before Phase 05 can be implemented
- D. They are independent with no connection

SECTION B — APPLIED SCENARIOS

Question 48

[Phase 06 — Incident Response]

SIEM alerts on potential data exfiltration from a finance server. What happens at the Investigation stage?

- A. Block the external IP at the firewall
- B. Check whitelist for false positive
- C. Examine full log context — what data was accessed, was it authorised, which user, did exfiltration succeed
- D. Create ticket and assign to IT Support

SECTION A — CORE CONTENT

Question 49

[Phase 06 — Incident Response]

After containing a phishing incident (credentials reset, malware scanned, domain blocked), what happens NEXT?

- A. Nothing — incident is resolved
- B. Documentation & Closure — record actions, update rules, add IOCs to MISP, close case
- C. Escalate to law enforcement
- D. Rebuild entire email server

SECTION B — APPLIED SCENARIOS

Question 50

[Phase 06 — Evidence Preservation]

An analyst logs into a compromised server and browses files on the live system. What principle is violated?

- A. Least privilege
- B. Evidence preservation — interacting with a live system can alter or destroy forensic evidence
- C. SLA response time
- D. Network segmentation

SECTION A — CORE CONTENT

Question 51

[Phase 06 — Incident Response]

How does Phase 06 transition into Phase 07?

- A. They happen simultaneously
- B. Phase 07 only starts for severe incidents
- C. Once the threat is contained/mitigated in Phase 06, Phase 07 restores systems, conducts RCA, and builds resilience
- D. Phase 07 replaces Phase 06 in mature organisations

SECTION B — APPLIED SCENARIOS

Question 52

[Cross-Phase — Full Cycle]

Map actions to phases: (A) Document servers, (B) Convert logs to standard schema, (C) Correlate failed logins, (D) Create SLA, (E) Auto-generate tickets, (F) Isolate compromised host, (G) Root cause analysis.

- A. A=01, B=02, C=03, D=04, E=05, F=06, G=07
- B. A=02, B=01, C=04, D=03, E=06, F=05, G=07
- C. A=01, B=03, C=02, D=05, E=04, F=07, G=06
- D. A=03, B=02, C=01, D=04, E=05, F=07, G=06

SECTION A — CORE CONTENT

Question 53

[Phase 01 — NIST IDENTIFY]

Which would NOT typically be documented in Phase 01?

- A. Network topology and IP ranges
- B. Inventory of hardware and software
- C. Specific SIEM correlation rules
- D. Critical system dependencies

SECTION B — APPLIED SCENARIOS

Question 54

[Phase 06 — Playbooks]

SOC gets insider threat alert. IR playbook says: verify identity, check authorisation, revoke access, escalate. Which phase provides this playbook?

- A. Phase 03 — SIEM owns the playbook
- B. Phase 04 — service management defines procedures
- C. Phase 05 — workflow automation provides playbooks guiding Phase 06
- D. Phase 07 — playbooks created after incidents

SECTION A — CORE CONTENT

Question 55

[Phase 02 — Aggregation]

In the 8-step pipeline, what is Step 7 (Document Attack Patterns) for?

- A. Create backup of security logs
- B. Record characteristic sequences and indicators of specific attack types for improving detection
- C. Generate tickets for each attack
- D. Normalise remaining events

Question 56

[Phase 03 — SIEM Outcomes]

Which is NOT a primary SIEM outcome?

- A. Comprehensive infrastructure visibility
- B. Rapid threat detection via real-time monitoring
- C. Automatic patching of vulnerable systems
- D. Regulatory compliance through log management

SECTION B — APPLIED SCENARIOS

Question 57

[Phase 06 — Coordination]

During a major incident, the IR team, network team, and management all need different information. Which Phase 04 concept handles this?

- A. Data normalisation
- B. Communication plan and escalation paths from service management
- C. Log aggregation
- D. Workflow automation triggers

CyberOps Mock Test — Answer Key

Quick Answer Grid

1. C	2. B	3. B	4. D	5. B	6. C
7. C	8. B	9. D	10. B	11. B	12. D
13. B	14. C	15. C	16. C	17. B	18. B
19. B	20. B	21. B	22. B	23. B	24. A
25. C	26. C	27. B	28. B	29. B	30. B
31. B	32. B	33. B	34. B	35. D	36. B
37. B	38. B	39. B	40. B	41. B	42. B
43. C	44. B	45. D	46. B	47. B	48. C
49. B	50. B	51. C	52. A	53. C	54. C
55. B	56. C	57. B			

Detailed Explanations

Q1. [Process Cycle Overview]

Correct: C

Phase 07 creates a feedback loop back to Phase 01 (IT Systems Landscape). After recovering from an incident, lessons learned update the landscape documentation, making the entire cycle continuous rather than linear.

Q2. [Phase 02 — Normalisation]

Correct: B

All timestamps must be converted to ISO 8601 format (YYYY-MM-DDTHH:MM:SSZ), preferably in UTC.

Q3. [Phase 02 — Normalisation]

Correct: B

The four required fields are normalised_timestamp, event_type, source_type, and severity. All other fields are optional — fill with empty string if unavailable, never omit from the template.

Q4. [Phase 02 — Aggregation]

Correct: D

Simple counting tells you how many events occurred but not WHEN they occurred relative to each other. Correlation is needed to identify timing patterns.

Q5. [Phase 03 — SIEM]

Correct: B

SEM provides real-time monitoring, event correlation, and alerts. SIM handles long-term storage and historical analysis. Together they form SIEM.

Q6. [Phase 03 — Correlation Rules]

Correct: C

Alert fidelity = true positives / total alerts = 1/2 = 50%. The monitoring server is a false positive.

Q7. [Phase 03 — False Positives]

Correct: C

Whitelisting excludes known-good sources from triggering alerts, improving accuracy from 50% to 100%. It acknowledges these sources — it doesn't ignore them entirely or block them.

Q8. [Phase 04 — Severity Algorithm]

Correct: B

Step 2: 8 events = HIGH. Step 3: 10:30 PM is off-hours → escalate one level → CRITICAL. Step 4: Not whitelisted. Final = CRITICAL, 15-minute SLA.

Q9. [Phase 04 — Severity Algorithm]

Correct: D

The whitelist check ALWAYS downgrades to LOW, regardless of event count or time. Whitelist override takes absolute precedence for known-good sources.

Q10. [Phase 04 — SLAs]

Correct: B

CRITICAL = Incident Response team, 15-minute SLA. HIGH = SOC (1 hr), MEDIUM = Network Security (4 hrs), LOW = IT Support (8 hrs).

Q11. [Phase 04 — KPIs]

Correct: B

A jump from 10% to 40% means more incidents are reaching CRITICAL level, suggesting increased threat activity.

Q12. [Phase 05 — Workflow Automation]

Correct: D

Orchestration coordinates multiple automated processes to execute complex workflows in sequence.

Q13. [Phase 06 — Alert Lifecycle]

Correct: B

Triage is specifically about reviewing alert details, checking whitelists and known-good sources, and determining if the alert is genuine.

Q14. [Phase 07 — Remediation]

Correct: C

Containment FIRST (isolate systems), then Eradication (remove threat), then Recovery (restore operations), then Resilience (prevent future attacks).

Q15. [Phase 07 — Case Study]

Correct: C

Unusual database queries were flagged by the monitoring system — demonstrating how Phase 03 detection feeds into Phase 06/07.

Q16. [Lab Skills]

Correct: C

Docker ensures consistency and isolation — not speed, SIEM requirements, or threat detection.

Q17. [Lab Skills]

Correct: B

Collection → Parsing → Normalisation → Visualisation → Analysis.

Q18. [Log Analysis]

Correct: B

This matches an attack chain: initial access attempt, pivot to alternative entry, then lateral movement to a database server within 30 seconds.

Q19. [Operational Analysis]

Correct: B

Faster detection = better monitoring. Slower resolution = bottlenecks in response — possibly needing more automation (Phase 05) or staffing.

Q20. [Severity Calculation]

Correct: B

172.16.0.50: 4 events = MEDIUM, off-hours → HIGH. 10.0.0.10: whitelist ALWAYS overrides to LOW regardless of count or time.

Q21. [Threat Intelligence]

Correct: B

IOCs are forensic evidence suggesting malicious activity — malicious IPs, file hashes, domain names. Threat intel feeds provide these to enrich SIEM analysis.

Q22. [Threat Intelligence]

Correct: B

Strategic = broad trends, attacker motivations, risk posture for leadership. Tactical = specific technical indicators for SOC analysts.

Q23. [MITRE ATT&CK;]

Correct: B

MITRE ATT&CK; maps adversary tactics, techniques, and procedures (TTPs) into stages. Your Week 7 lab references these exact stages.

Q24. [SOC Tiers]

Correct: A

Tier 1 handles triage. Tier 2 investigates escalated incidents. Tier 3 does proactive threat hunting and advanced forensics.

Q25. [Digital Forensics]

Correct: C

Hashing creates a unique fingerprint. Re-hashing later proves no tampering — essential for chain of custody and legal proceedings.

Q26. [GDPR & Compliance]

Correct: C

GDPR Article 33 requires notification within 72 hours. Article 34 covers notifying affected individuals.

Q27. [BC/DR]

Correct: B

RTO = maximum acceptable downtime. RPO = maximum data loss (time since last backup).

Q28. [Vulnerability Management]

Correct: B

Vulnerability management continuously scans, assesses risk (CVSS), patches, and verifies — including third-party components.

Q29. [NIST CSF 2.0 — GOVERN]

Correct: B

GOVERN covers cybersecurity governance, risk management strategy, and alignment with business objectives. Maps to Phase 04.

Q30. [Document Analysis]

Correct: B

MTTD = time between incident onset (13:00) and detection (14:32) = 1 hour 32 minutes.

Q31. [Process Cycle Mapping]

Correct: B

Phase 01 (NIST IDENTIFY) should document authorised devices and enforce network access control policies.

Q32. [Log Sources]

Correct: B

Random subdomain requests to a single domain = classic DNS tunnelling/C2 indicator. SIEM behavioural analytics would flag this.

Q33. [Critical Thinking]

Correct: B

Phase 04 should have standardised procedures and escalation paths. Phase 05 should have automated initial response for consistency. The SIEM did its job detecting.

Q34. [Change Management]

Correct: B

Change management controls planning, testing, and approving infrastructure changes. Unauthorised changes are a top cause of security incidents.

Q35. [Full Cycle Walkthrough]

Correct: D

Writing new detection rules AFTER an incident is Phase 07 activity — enhancing monitoring as a lesson learned, feeding back into the cycle.

Q36. [Phase 02 — Normalisation]

Correct: B

4625 = authentication_failure. 4624 = success, 4688 = process_execution, 5140 = network_access.

Q37. [STIX/TAXII]

Correct: B

STIX defines the format for threat intel (IOCs, TTPs), TAXII defines how to transport and share it between organisations.

Q38. [Service Management]

Correct: B

Without a SOC: limited specialist expertise, slower response. They CAN still use SIEMs, tickets, and normalisation.

Q39. [Phase 05 — Terminology]

Correct: B

Playbooks are fully automated sequences. Runbooks are detailed procedural docs that may combine automated and manual steps.

Q40. [CVSS]

Correct: B

CVSS 9.8 = Critical. Scores range 0-10. Requires immediate attention.

Q41. [Phase 01 — IT Systems Landscape]

Correct: B

Phase 01 maps to NIST IDENTIFY — documenting the overall structure and architecture of the IT environment.

Q42. [Phase 01 — IT Systems Landscape]

Correct: B

Phase 01 feeds every subsequent phase. Without a complete landscape, there are blind spots across the entire cycle.

Q43. [Phase 01 — IT Systems Landscape]

Correct: C

Incomplete Phase 01 means no log collection, no monitoring, no correlation, and no IR coverage for those assets.

Q44. [Phase 01 — Asset Management]

Correct: B

Undocumented servers create cascading gaps across every phase of the cycle.

Q45. [Phase 06 — Incident Response]

Correct: D

Phase 06 maps to NIST RESPOND — containing, mitigating, and remediating identified threats.

Q46. [Phase 06 — Incident Response]

Correct: B

Containment is always first — isolate to prevent lateral movement. Analysis, restoration, and communication come after.

Q47. [Phase 06 — Incident Response]

Correct: B

Phase 05 supports Phase 06 with automation but doesn't replace human decision-making for complex incidents.

Q48. [Phase 06 — Incident Response]

Correct: C

Investigation (Stage 3) examines full context. Blocking = Response (Stage 4). Whitelist = Triage (Stage 2).

Q49. [Phase 06 — Incident Response]

Correct: B

Documentation & Closure (Stage 5) ensures the organisation learns from the incident and feeds into Phase 07.

Q50. [Phase 06 — Evidence Preservation]

Correct: B

Live interaction changes timestamps and may trigger evidence deletion. Best practice: image first, hash, investigate the copy.

Q51. [Phase 06 — Incident Response]

Correct: C

Phase 06 handles the immediate crisis. Phase 07 picks up with restoration, root cause analysis, and long-term resilience.

Q52. [Cross-Phase — Full Cycle]

Correct: A

A=01 (landscape), B=02 (normalisation), C=03 (SIEM correlation), D=04 (SLA), E=05 (automation), F=06 (IR containment), G=07 (RCA).

Q53. [Phase 01 — NIST IDENTIFY]

Correct: C

Phase 01 documents WHAT exists. SIEM correlation rules are Phase 03. Phase 01 identifies the SIEM itself, not its detection logic.

Q54. [Phase 06 — Playbooks]

Correct: C

Playbooks are Phase 05 (Workflow Automation). Phase 03 detects, Phase 05 provides the playbook, Phase 06 executes it.

Q55. [Phase 02 — Aggregation]

Correct: B

Step 7 documents distinct attack patterns from correlated events — improving detection rules, training, and threat hunting.

Q56. [Phase 03 — SIEM Outcomes]

Correct: C

SIEMs detect threats and manage logs — they don't patch systems. Patching is vulnerability/configuration management.

Q57. [Phase 06 — Coordination]

Correct: B

Phase 04 defines communication plans and escalation paths — ensuring the right people get the right information.

Good luck with the test!